

& DPDP Rules 2025

Comprehensive Compliance Guide

Standards · Best Practices · Anti-Patterns · Implementation Roadmap

Jurisdiction	India (extraterritorial reach for non-Indian entities serving Indian Data Principals)
Enacted	August 11, 2023 (Presidential Assent)
Rules Notified	November 13, 2025 (DPDP Rules 2025)
Full Enforcement	May 13, 2027
Max Penalty	■250 crore per violation
Guide Version	June 2026 Based on EY, KPMG, Deloitte, PwC, MeitY Sources

Compiled from KPMG India, EY India, Deloitte India, PwC India, MeitY, Fisher Phillips, CyrilAmarchand Mangaldas, Scrut.io & Leading Compliance Authorities

Table of Contents

1.	Executive Summary & Why This Matters Now	3
2.	Legislative Background & Constitutional Foundation	4
3.	Core Framework — Key Definitions & Scope	4
4.	Seven Guiding Principles of the DPDP Act	5
5.	Data Principal Rights	5
6.	Data Fiduciary Obligations	6
7.	Significant Data Fiduciary (SDF) — Enhanced Obligations	7
8.	Consent Management — Standards & Best Practices	7
9.	Data Discovery & Classification Best Practices	9
10.	Data Protection & DLP Controls	9
11.	Breach Notification — Standards & Timelines	10
12.	DPO as a Service & Managed Compliance	10
13.	Penalty Structure — Full Schedule	11
14.	Implementation Roadmap — Phase-by-Phase	12
15.	Anti-Patterns — What NOT to Do	13
16.	DPDP vs GDPR — Comparative Analysis	14
17.	Technology Architecture for Compliance	15
18.	Compliance Checklist	16
19.	Key Takeaways & Strategic Recommendations	17

1. Executive Summary & Why This Matters Now

■ **Critical Alert:** The DPDP Act 2023 is now enforceable. With penalties reaching ■250 crore per violation and full enforcement commencing May 13, 2027, organizations operating in India have a rapidly closing window to achieve compliance. The Data Protection Board of India (DPBI) became operational in November 2025 — enforcement is no longer theoretical.

India's Digital Personal Data Protection (DPDP) Act, 2023 represents the country's first comprehensive standalone data privacy law — a landmark shift from the fragmented regime under the IT Act 2000. Together with the DPDP Rules 2025 notified on November 13, 2025, it establishes a citizen-centric, enforceable framework for all digital personal data processing.

Why Organizations Must Act Immediately:

Risk Area	Implication
Regulatory Risk	Penalties up to ■250 crore per violation with no cure period once enforcement begins
Reputational Risk	Data breaches and non-compliance will be publicly adjudicated by the DPBI
Competitive Advantage	Early compliance builds consumer trust — a differentiator in fintech, SaaS, and e-commerce
Global Interoperability	DPDP-compliant posture eases GDPR alignment and cross-border data partnerships
2026 is the Build Year	Typical enterprise compliance programs take 9–12 months; time is running out

2. Legislative Background & Constitutional Foundation

The DPDP Act 2023 is the culmination of nearly two decades of legislative effort, anchored in the 2017 Supreme Court landmark judgment in *Justice K.S. Puttaswamy (Retd.) v. Union of India*, which unanimously recognized the **Right to Privacy as a fundamental right** under Article 21 of the Constitution of India.

Year	Milestone
2000	IT Act 2000 — foundational digital law, limited privacy coverage
2011	SPDI Rules — first rules on sensitive personal data (IT Act)
2017	Puttaswamy Judgment — Privacy declared a fundamental right (Article 21)
2018-22	Multiple draft bills (PDP Bill 2019 withdrawn in 2022) after extensive parliamentary review
Aug 2023	DPDP Act 2023 receives Presidential Assent — India's 1st standalone data law
Nov 2025	DPDP Rules 2025 notified; Data Protection Board of India (DPBI) becomes operational
Nov 2026	Phase 2: Consent Manager Framework becomes operational
May 2027	Phase 3: Full enforcement — all obligations enforceable, no cure period

3. Core Framework — Key Definitions & Scope

Term	Definition
Data Principal	The individual whose personal data is being processed. For a child (under 18), the parent or lawful guardian acts on their behalf.
Data Fiduciary	Any entity — person, company, or government body — that determines the purpose and means of processing personal data. Bears primary compliance responsibility.
Data Processor	An entity that processes personal data on behalf of a Data Fiduciary. Subject to contractual compliance obligations.
Personal Data	Any data about an identifiable individual. Unlike GDPR, DPDP Act does not create a special 'sensitive personal data' category — all personal data is equally protected.
Significant Data Fiduciary (SDF)	A Data Fiduciary designated by the Central Government based on volume, sensitivity of data, national security risk, or algorithmic risk. Faces enhanced obligations.

Consent Manager	A registered intermediary that provides a single, interoperable platform for Data Principals to give, manage, and withdraw consent across multiple Data Fiduciaries.
Data Protection Board (DPBI)	Independent corporate body established under Chapter 5 of the DPDP Act. Monitors compliance, investigates breaches, and imposes penalties.

Territorial Scope: The Act applies to (a) all processing of digital personal data within India, and (b) processing outside India if it involves offering goods/services to Data Principals in India. This extraterritorial reach means US, EU, and other international companies handling Indian user data are covered.

4. Seven Guiding Principles of the DPDP Act

1	Lawfulness, Fairness & Transparency Data must be processed lawfully, fairly, and with full transparency to the Data Principal about what is collected and why.
2	Purpose Limitation Personal data can only be used for the specific, stated purpose for which consent was obtained. Secondary use requires fresh consent.
3	Data Minimisation Only data that is strictly necessary for the stated purpose may be collected. 'Collect-all' strategies are prohibited.
4	Data Accuracy Fiduciaries must make reasonable efforts to ensure data is accurate and kept up to date, especially where inaccuracies could harm the Data Principal.
5	Storage Limitation Data must be retained only as long as necessary for the stated purpose. Once the purpose is fulfilled or consent is withdrawn, data must be deleted.
6	Security Safeguards Reasonable technical and organizational measures must protect data from unauthorized access, breaches, alteration, or destruction.
7	Accountability The Data Fiduciary is accountable for demonstrating compliance. The burden of proof rests with the organization, not the regulator.

5. Data Principal Rights

Right	What It Means for Organizations
Right to Access	Obtain a summary of personal data processed and the activities for which it is being used. Request details of all Data Fiduciaries and processors with access.

Right to Correction	Request correction of inaccurate personal data. Fiduciaries must respond within 90 days.
Right to Erasure	Request deletion of personal data when the purpose of collection has been fulfilled or consent is withdrawn.
Right to Grievance Redressal	Lodge complaints with the Data Fiduciary's Grievance Officer; escalate to the Data Protection Board if unresolved.
Right to Nominate	Nominate another individual to exercise rights on their behalf in the event of death or incapacity.
Right to Withdraw Consent	Withdraw consent at any time. Withdrawal must be as easy as giving consent. Fiduciary must cease processing post-withdrawal.

■ **Operational Requirement:** All Data Principal requests — access, correction, erasure — must be fulfilled within 90 days. Build automated Rights Management workflows; manual processes will not scale at enterprise volume.

6. Data Fiduciary Obligations — The Compliance Core

6.1 Notice Requirements

Before processing personal data, every Data Fiduciary must issue a **standalone notice** in plain, clear language (not buried in Terms & Conditions). The notice must:

- Provide an itemized description of personal data to be processed
- State the specific purpose for which each data element is collected
- Explain how Data Principals can exercise their rights
- Provide a communication link for consent withdrawal and complaint filing
- Be available in English AND in any of the 22 scheduled languages of the Indian Constitution relevant to the user base
- Cover data already being processed before the Rules came into effect (retrospective notice requirement)

6.2 Consent Standards

Consent under the DPDP Act must be:

Attribute	Requirement
Free	No coercion, conditioning of service on unnecessary data collection
Specific	Granular — one purpose per consent request; no bundled consents
Informed	Preceded by a clear, itemized notice
Unconditional	Data Principal cannot be penalized for withholding non-essential consent
Unambiguous	Affirmative action required; silence, pre-ticked boxes, or inaction are NOT valid consent

6.3 Security Safeguards

Data Fiduciaries must implement 'reasonable security safeguards' — a standard that encompasses both technical and organizational measures proportionate to the nature, volume, and sensitivity of data processed. Key requirements include:

- Encryption of personal data in transit and at rest
- Strict access controls and least-privilege principles
- Audit logging with minimum 1-year retention for compliance evidence
- Regular vulnerability assessments and penetration testing
- Documented incident response and breach notification protocols

- Security clauses in all Data Processor (vendor) agreements

6.4 Vendor / Data Processor Obligations

Compliance responsibility rests with the Data Fiduciary even when processing is carried out by a third-party Data Processor. The DPDP Rules expressly require:

- Valid written contracts with all Data Processors specifying security and compliance obligations
- Contractual requirement for Processors to assist with data principal rights requests
- Processor obligations for breach support, deletion/return of data, and audit access
- Due diligence assessments before onboarding new Processors

6.5 Children's Data — Heightened Standards

The DPDP Act defines a child as any person under 18 — a broader definition than GDPR's 16. Special requirements apply:

- Verifiable parental/guardian consent before processing any child's data
- Prohibition on behavioral monitoring or targeted advertising directed at children
- No processing that could cause harm to a child
- Verification methods: existing known information, digital tokens, or Digital Locker verification

7. Significant Data Fiduciary (SDF) — Enhanced Obligations

SDF Designation Criteria: The Central Government designates SDFs based on volume and sensitivity of data processed, risk to national security, risk from algorithmic decision-making, and potential impact on sovereignty and democratic processes. Large tech platforms, financial services companies, and healthcare aggregators are expected to be among the first designated.

Obligation	Description
Appoint India-based DPO	DPO must report directly to the Board of Directors. Serves as primary DPDP compliance lead and grievance contact.
Annual DPIA	Conduct Data Protection Impact Assessments annually. Must outline processing purpose, Data Principal rights, and comprehensive risk mitigation.
Independent Data Auditor	Engage an independent auditor to assess DPDP compliance. Share significant observations/gaps with the DPBI periodically.
Algorithmic Auditor	Assess all algorithms and AI/ML models used in personal data processing for fairness, bias, and compliance.
Algorithmic Fairness Assessment	Evaluate automated decision-making systems that impact Data Principals.
Data Localisation	Comply with any Central Government-specified data localisation requirements (specific categories yet to be notified).

8. Consent Management — Industry Standards & Best Practices

Consent management is the operational backbone of DPDP compliance. Leading consultancies — KPMG, EY, Deloitte, PwC — converge on a **Privacy-by-Design** approach where consent workflows are embedded into systems from the ground up, not bolted on post-facto.

8.1 KPMG's Four Pillars of Consent Governance

- **Transparency:** Clear, plain-language notices before every data collection event; itemized purpose statements
- **Purpose Discipline:** Strict enforcement of purpose limitation — data used ONLY for stated purpose; automated controls block secondary use

- **Accountability:** Documented audit trails for every consent event; board-level oversight of data governance
- **Control:** Data Principal-facing dashboards to view, modify, and withdraw consent; withdrawal mechanisms as simple as consent grant

8.2 EY's Consent Management Framework

EY's India DPDP practice recommends a **four-layer consent architecture**:

- **Layer 1 — Collection:** Consent captured at every entry point (web, app, IVR, in-store). Granular purpose-level consent, not blanket consent.
- **Layer 2 — Storage:** Consent records stored in an immutable, time-stamped consent ledger. Evidence-grade records for regulatory audits.
- **Layer 3 — Enforcement:** Automated policy engine that blocks data processing unless valid, active consent exists for the specific purpose.
- **Layer 4 — Governance:** Regular consent audits; expiry workflows; automated outreach for consent refresh when purposes change.

8.3 Deloitte's Consent Manager Integration Strategy

Deloitte recommends early engagement with the **Consent Manager framework** (operational from November 2026) as an opportunity, not just a compliance burden:

- Integrate with registered Consent Managers to provide users a single dashboard across all your platforms
- Implement interoperable consent APIs that can communicate with Consent Manager intermediaries
- Design consent withdrawal propagation to ensure all downstream systems and processors cease processing within defined SLAs
- Build consent lifecycle management — including expiry, renewal, and purpose-change re-consent workflows

8.4 PwC's Consent Maturity Model

Maturity Level	Characteristics
Level 1 — Reactive	Static checkboxes, PDF notices, no withdrawal mechanism. Non-compliant.
Level 2 — Defined	Digital consent forms, basic logging. Partially compliant.
Level 3 — Managed	Purpose-level granular consent, automated enforcement, 90-day response SLAs. Substantially compliant.

Level 4 — Optimized	AI-powered consent management, predictive compliance, consent manager integration, real-time dashboards. Fully compliant & audit-ready.
---------------------	---

9. Data Discovery & Classification — Best Practices

You cannot protect what you cannot find. Data Discovery is universally cited by KPMG, EY, Deloitte, and MeitY as the **foundational first step** in DPDP compliance. The objective is a complete, living map of all personal data across your organization.

Discovery Scope — Where to Look:

- **Databases & Data Warehouses:** SQL/NoSQL databases, data lakes, analytics warehouses — profile for PII fields
- **SaaS Applications:** CRM (Salesforce), HRMS (Workday, SAP), ERP, Marketing Automation — often largest uncontrolled stores
- **Cloud Storage:** AWS S3, Azure Blob, GCP Storage — unstructured data with embedded PII in documents, logs
- **Endpoints & Devices:** Employee laptops, mobile devices — local copies of personal data
- **APIs & Microservices:** Data flows between services; often undocumented PII transit paths
- **AI/ML Systems:** Training datasets, model inputs, inference logs — frequently overlooked PII exposure
- **Email & Collaboration:** Outlook, Gmail, Slack, Teams — contracts, employee data, customer PII in unstructured form
- **Backup & Archive:** DR replicas, tape archives — often exempt from deletion workflows incorrectly

Record of Processing Activities (RoPA) — Mandatory Foundation:

Following discovery, organizations must build and maintain a **RoPA** (Record of Processing Activities) documenting:

- Data categories processed
- Purpose of processing
- Lawful basis (consent or legitimate use)
- Retention periods
- Recipients / processors with access
- Cross-border transfer status
- Security measures applied
- Last review date

■ **Tool Recommendation:** Automated data discovery platforms (e.g., Varonis, Securiti.ai, BigID, OneTrust) can reduce discovery timelines from months to weeks. For API-centric architectures, runtime visibility tools (e.g., Levo.ai) identify data flows that static scanning misses.

10. Data Protection & DLP Controls

The 'reasonable security safeguards' standard requires a layered defense-in-depth strategy. Leading frameworks converge on the following control domains:

Technical Controls

- End-to-end encryption (AES-256) for data at rest and TLS 1.3 for data in transit
- Role-based access control (RBAC) + attribute-based access control (ABAC)
- Data Loss Prevention (DLP) tools to detect and block unauthorized exfiltration
- Database Activity Monitoring (DAM) with anomaly detection
- Pseudonymisation and data masking for non-production environments
- Multi-factor authentication for all systems processing personal data

Organizational Controls

- Formal Data Classification Policy (Public / Internal / Confidential / Restricted)
- Privacy Impact Assessment (PIA) process for new projects touching personal data
- Annual security awareness training for all employees with access to personal data
- Background verification for employees in data-sensitive roles
- Clear desk and clear screen policy for physical security
- Documented Data Retention and Deletion Policy with automated enforcement

Vendor Controls

- Security questionnaire and due diligence for all Data Processors
- Contractual security requirements aligned to DPDP Rules
- Right-to-audit clauses in all processor agreements
- Regular third-party security assessments (VAPT, SOC 2 reports)

11. Breach Notification — Standards & Timelines

■■ Critical: ALL personal data breaches must be reported — regardless of severity or whether damage was caused. There is no materiality threshold. Failure to notify the DPBI or affected Data Principals attracts a penalty of up to ■200 crore.

Breach Notification Timeline:

Timeline	Action Required
Immediate	Contain the breach; activate incident response team; preserve evidence
Discovery + 0h	Notify the Data Protection Board of India (DPBI) immediately upon discovery with: nature of breach, categories affected, approximate number of Data Principals affected, likely consequences, remediation measures taken
Discovery + 72h	Notify all affected Data Principals with: nature and extent of breach, timing and location, consequences, mitigating measures, guidance on protective action
Post-Breach	Submit a final breach report to DPBI; conduct root cause analysis; implement systemic fixes; update incident response plan

Incident Response Program — Best Practice Components:

- Documented IR Policy with defined roles (CISO, DPO, Legal, PR, HR, IT)
- Automated breach detection tooling (SIEM, EDR, DLP alerts)
- Pre-approved breach notification templates (DPBI and Data Principal versions)
- Tabletop exercises at least annually — test your 72-hour notification capability
- Forensic investigation retainer with a qualified cybersecurity firm
- Cyber insurance coverage aligned to DPDP penalty exposure

12. DPO as a Service & Managed Compliance

For Significant Data Fiduciaries, an India-based Data Protection Officer (DPO) is mandatory. For all other organizations, a DPO or equivalent Privacy Lead is strongly recommended. The miniOrange model of **DPO as a Service** and managed compliance is gaining rapid adoption among mid-market enterprises.

DPO Responsibilities Under DPDP:

- Oversee and coordinate DPDP compliance program across all business functions

- Serve as primary contact for the Data Protection Board of India
- Manage the Data Principal grievance redressal process
- Lead Data Protection Impact Assessments (DPIAs) for high-risk processing
- Monitor regulatory developments and update compliance posture
- Conduct employee training and build privacy-first culture
- Review and approve data processing agreements with third parties
- Prepare and present board-level compliance reports

DPO as a Service — When to Consider:

Organizations that lack the budget or scale for a full-time in-house DPO can leverage managed compliance services from firms such as **miniOrange**, **Infodot Technologies**, **PwC India**, **EY India**, **KPMG India**, **Deloitte India** and others. Key service components include:

- DPDP Gap Assessment — identify exactly where you stand on consent, data flows, retention, vendor exposure
- Consent Management platform deployment and ongoing management
- Data Discovery & Classification — automated scanning of databases, SaaS apps, cloud, and endpoints
- Regulatory coordination and Data Protection Board liaison
- Grievance management and Data Principal rights fulfillment
- Audit readiness and ongoing compliance monitoring
- DPIA and Data Protection Impact Assessment services

13. Penalty Structure — Full Schedule

Unlike GDPR's percentage-of-revenue model, DPDP penalties are fixed caps per violation. Penalties are discretionary and proportional — the DPBI considers severity, repetition, mitigation effort, and cooperation before imposing fines.

Violation	Maximum Penalty	Approx. USD
Failure to implement reasonable security safeguards — resulting in a breach	■250 crore	~\$30 million
Failure to notify DPBI or Data Principals of a personal data breach	■200 crore	~\$24 million
Breach of children's data processing obligations	■200 crore	~\$24 million
Breach of additional Significant Data Fiduciary obligations	■150 crore	~\$18 million
Breach of any other provision of the Act or Rules	■50 crore	~\$6 million
Data Principal violations (false complaints, impersonation, etc.)	■10,000	~\$120

■■ No Cure Period: Unlike some global regimes, the DPDP Act does not provide a grace window to fix non-compliance before penalties are imposed. Organizations must be fully compliant before May 13, 2027. Appeals can be made to the TDSAT within 60 days, and to the Supreme Court thereafter.

14. Implementation Roadmap — Phase-by-Phase (2025–2027)

■ Industry Standard: EY, KPMG, and Deloitte all recommend beginning compliance programs immediately. Typical enterprise DPDP programs require 9–12 months. With enforcement in May 2027, organizations starting today have adequate — but not excess — time.

Phase 1: Foundation (Months 1–3)

- Conduct a comprehensive DPDP Gap Assessment against Act and Rules requirements
- Data mapping: inventory all personal data across cloud, SaaS, on-premises, and endpoints
- Classify data by processing purpose and identify lawful basis (consent vs. legitimate use)
- Conduct a RoPA (Record of Processing Activities) for all processing activities

- Review existing privacy policies, consent mechanisms, and vendor contracts for compliance gaps
- Assess current security controls against 'reasonable safeguards' standard
- Establish a cross-functional DPDP steering committee (Legal, IT, HR, Marketing, Procurement)

Phase 2: Build (Months 4–8)

- Redesign consent workflows to meet free, specific, informed, unconditional, unambiguous standard
- Deploy consent management platform with audit trails and withdrawal mechanisms
- Draft and publish DPDP-compliant privacy notices in English + required Indian languages
- Implement Data Principal rights management system (access, correction, erasure, nomination)
- Build automated 72-hour breach notification workflow
- Implement Data Retention Policy with automated deletion jobs
- Renegotiate or amend all Data Processor agreements to include DPDP security requirements
- Deploy technical controls: encryption, access controls, DLP, audit logging
- Appoint Grievance Redressal Officer and publish contact details

Phase 3: Validate (Months 9–12)

- Conduct a full internal or third-party DPDP compliance audit
- Issue retrospective notices for data collected before Rules came into effect
- Run tabletop exercises for incident response and breach notification
- Complete employee privacy training — all staff with data access
- Activate data retention and automated erasure policies
- SDFs: Appoint India-based DPO; initiate first annual DPIA; engage independent auditor
- Register with Consent Manager framework (Phase 2: November 2026)

Phase 4: Sustain (Ongoing Post-May 2027)

- Maintain continuous compliance monitoring program
- Annual DPIA refresh (SDFs mandatory; all Fiduciaries best practice)
- Quarterly Data Principal rights request review and SLA reporting
- Annual consent audit — verify consent records are valid and current
- Monitor MeitY and DPBI regulatory guidance for updates
- Annual board-level privacy governance review
- Integrate privacy assessment into all new product/system development (Privacy by Design)

15. Anti-Patterns — What NOT to Do

Drawn from global consulting firm advisories and enforcement patterns from comparable regimes (GDPR, PDPA), these are the most common pitfalls organizations must avoid under the DPDP Act:

■ Bundled Consent	Combining multiple purposes into a single consent checkbox (e.g., 'I agree to the Terms & Conditions and Privacy Policy'). Each purpose requires separate, granular consent under DPDP.
■ Pre-ticked Boxes	Treating silence or inaction as consent. DPDP requires an affirmative, unambiguous action. Pre-ticked boxes for marketing, analytics, or data sharing are explicitly prohibited.
■ 'Notice' Buried in T&Cs;	Embedding privacy notices inside lengthy Terms & Conditions or making them accessible only through hyperlinks. DPDP requires a standalone, plain-language notice before data collection.
■ Treating Compliance as a One-Time Project	Deploying a consent pop-up and considering compliance 'done.' DPDP requires continuous monitoring, annual audits, regular consent reviews, and real-time rights fulfillment. Compliance is a program, not a project.
■ Ignoring Data Minimisation	Collecting 'just in case' data — e.g., collecting date of birth for a newsletter signup or home address for a digital-only service. Each field collected must have a documented, necessary purpose.
■ No Data Retention Policy	Retaining personal data indefinitely because 'storage is cheap.' The Act mandates deletion when the purpose is fulfilled or consent is withdrawn. Unlimited retention is a direct violation.
■ Shadow IT & Untracked SaaS	Personal data flowing into unapproved SaaS tools (e.g., team using a free spreadsheet tool that stores customer data abroad). Fiduciaries are responsible for ALL processing including that done through shadow IT.
■ Vendor Blind Spot	Assuming vendors are responsible for their own DPDP compliance. The Data Fiduciary bears primary responsibility. Unvetted Data Processors are among the highest-risk vectors.

■ Breach Under-Reporting	Assessing breach severity internally and deciding to self-suppress because 'no damage was caused.' ALL breaches must be reported to the DPBI. There is no materiality threshold.
■ Children's Data Without Verification	Collecting user age through a self-declared checkbox (e.g., 'I am 18+') and calling it verifiable parental consent. DPDP requires robust verification processes — self-declaration alone is insufficient.
■ Ignoring Extraterritorial Scope	Non-Indian companies assuming the DPDP Act doesn't apply to them. If your service targets Indian users and you process their data, you are a Data Fiduciary regardless of where you are incorporated.
■ No Language Localisation	Publishing privacy notices only in English. DPDP Rules require notices to be available in languages from the Indian Constitution's Eighth Schedule relevant to your user demographic.
■ DPO Without Board Access	Appointing a DPO but burying them in the IT or Legal department with no board access. The Act requires the DPO to report directly to the Board of Directors for Significant Data Fiduciaries.
■ Privacy Washing	Creating elaborate privacy policies on paper without operational implementation (no consent records, no deletion workflows, no breach response plan). Regulators assess operational evidence, not paper compliance.

16. DPDP vs GDPR — Comparative Analysis

Organizations with existing GDPR compliance have a valuable foundation, but DPDP has significant structural differences that require dedicated attention.

Dimension	GDPR (EU)	DPDP Act 2023 (India)
Lawful Bases	6 bases: consent, legitimate interest, contract, legal obligation, vital interest, public task	2 bases: Consent + Legitimate Use (limited specific exceptions)
Sensitive Data	Special categories (health, biometrics, religion, etc.) with extra protections	No formal sensitive data category - all personal data equally protected
Definition of Child	Under 16 (member state may set 13)	Under 18 (applies uniformly)
Penalty Model	Up to 4% of global annual revenue or EUR 20M, whichever higher	Fixed cap: up to INR 250 crore per violation
Cross-Border Transfers	Adequacy decisions, SCCs, BCRs, derogations	Government-approved list of countries; transfer rules yet to be fully notified
Data Protection Officer	Mandatory for high-risk processors; optional otherwise	Mandatory for Significant Data Fiduciaries only
Right to Portability	Explicit right to data portability	No explicit portability right in current Act
Legitimate Interest	Broad basis including commercial interests	Very narrow - limited to specific state/legal functions
Enforcement Authority	National Data Protection Authorities (DPAs)	Data Protection Board of India (DPBI) - single national authority
Language Requirements	Language of member state	22 languages from Indian Constitution Eighth Schedule
Algorithmic Accountability	Profiling rights; right not to be subject to automated decisions	Algorithmic audits mandatory for SDFs (broader scope)

17. Technology Architecture for DPDP Compliance

A mature DPDP compliance technology stack typically comprises five layers. Organizations should architect these as an integrated platform, not siloed point solutions:

Layer 1: Discovery & Inventory

- Automated data discovery tools (BigID, Varonis, Securiti.ai, OneTrust Data Mapping)
- API runtime visibility (Levo.ai, Salt Security) for dynamic data flow mapping
- Cloud Security Posture Management (CSPM) for cloud data stores
- RoPA management platform with automated population from discovery findings

Layer 2: Consent & Notice Management

- Consent Management Platform (OneTrust, TrustArc, CookieYes) for web/app consent
- Consent ledger with immutable audit trail and time-stamping
- Multi-language notice management system (22+ Indian languages)
- Consent Manager API integration layer (for November 2026 framework)

Layer 3: Data Principal Rights

- Automated DSAR (Data Subject Access Request) fulfillment workflow
- Identity verification for rights requests
- 90-day SLA tracking and escalation management
- Rights request portal accessible in multiple languages

Layer 4: Security & Protection

- Data Loss Prevention (DLP) — network, endpoint, cloud
- Database Activity Monitoring (DAM) with anomaly detection
- Privileged Access Management (PAM) for sensitive data stores
- SIEM + SOAR for breach detection and automated response
- Encryption key management system

Layer 5: Governance & Reporting

- Compliance dashboards with real-time DPDP posture metrics
- DPIA management workflow (initiation, assessment, approval, review)
- Vendor risk management platform for processor oversight
- Board-level reporting templates and compliance scorecards
- Regulatory change management feed (MeitY, DPBI notifications)

18. Compliance Checklist — Pre-Enforcement Readiness

Data Foundation

- Data mapping completed across all systems (databases, SaaS, cloud, endpoints, APIs)
 - RoPA (Record of Processing Activities) documented and current
 - Data classification policy implemented (sensitivity tiers defined)
 - Data retention schedules documented with automated deletion workflows
 - Shadow IT inventory completed and unauthorized data stores addressed
-

Consent & Notice

- Standalone DPDP-compliant privacy notices published
 - Notices available in English + all relevant scheduled Indian languages
 - Granular, purpose-specific consent collection in place (no bundling)
 - Consent withdrawal mechanism as simple as consent granting
 - Immutable consent records stored with timestamps and audit trails
 - Retrospective notices issued for pre-existing data collections
 - Children's data: verifiable parental consent mechanism implemented
-

Data Principal Rights

- Rights request portal live and accessible
 - 90-day response SLA tracking system implemented
 - Identity verification process for rights requests established
 - Grievance Redressal Officer appointed and contact details published
 - Nomination mechanism for rights delegation in place
-

Security Controls

- Encryption implemented for data at rest and in transit
 - Access controls (RBAC/ABAC) implemented with least privilege
 - DLP tools deployed and tuned for personal data detection
 - Audit logging enabled with minimum 1-year retention
 - Incident Response Plan documented and tested
 - 72-hour breach notification workflow implemented and rehearsed
 - Annual VAPT (Vulnerability Assessment & Penetration Testing) scheduled
-

Vendors & Processors

- All Data Processor agreements reviewed and DPDP compliance clauses added
 - Third-party security due diligence process implemented
 - Right-to-audit provisions in all processor contracts
 - Processor inventory maintained and current
-

Governance

- Cross-functional DPDP steering committee established
 - DPO appointed (mandatory for SDFs; recommended for all)
 - Employee privacy training program launched
 - Board-level DPDP briefing conducted
 - SDFs: DPIA completed, independent auditor engaged
 - MeitY and DPBI regulatory monitoring process established
 - Full compliance audit (internal or third-party) completed before May 2027
-

19. Key Takeaways & Strategic Recommendations

For C-Suite & Board:

- DPDP compliance is a board-level governance imperative — personal liability for leadership may result from systemic failures
- Treat the ₹250 crore penalty cap as the floor of reputational risk, not the ceiling
- Invest in a formal DPDP compliance program now — reactive compliance after a breach or enforcement action is exponentially more costly
- Privacy posture is increasingly a competitive differentiator — consumers and B2B partners are asking about it
- Align DPDP compliance with your ESG and governance commitments

For CISOs & IT Leaders:

- Expand your security program scope: DPDP makes data governance a security function, not just a legal one
- Prioritize data discovery — you cannot protect what you cannot see
- Build 72-hour breach notification capability as an operational SLA, not an aspiration
- DLP, DAM, and access controls are now regulatory requirements, not optional security enhancements
- Integrate privacy requirements into DevSecOps — Privacy by Design from the first sprint

For Legal & Compliance Teams:

- Begin vendor contract remediation immediately — renegotiating hundreds of processor agreements takes time
- Build the consent management program now — the Consent Manager framework launches November 2026
- Issue retrospective notices for existing data as soon as possible — don't wait for enforcement
- Map your SDF exposure — understand whether you are likely to be designated and plan accordingly
- Monitor MeitY notifications for SDF list publication and cross-border transfer country list

■ **Final Recommendation:** The window between today (June 2026) and enforcement (May 2027) is 11 months — exactly the time leading consultancies estimate for enterprise compliance programs. Organizations that begin now will achieve audit-ready posture by enforcement date. Those that wait risk a reactive, expensive, and incomplete compliance scramble under regulatory scrutiny.

Sources & References: EY India — DPDP Act 2023 & Rules 2025 Compliance Guide; KPMG India — DPDP Act Simplified (Dec 2025); Deloitte India — DPDP Act 2023 Advisory; PwC India — DPDP Consumer Survey & Implementation Framework; MeitY — DPDP

Rules 2025 Official Notification; Fisher Phillips LLP — 8-Step DPDP Compliance Plan (Feb 2026); Scrut.io — DPDP Rules 2025 Implementation Guide; CyrilAmarchand Mangaldas — DPDP Final Rules Roadmap; RecordingLaw.com — India Data Privacy Laws Complete Guide (May 2026).

This guide is prepared for informational and compliance planning purposes. It does not constitute legal advice. Organizations should engage qualified legal counsel for jurisdiction-specific and fact-specific DPDP compliance guidance.